

Top 10 web hacking techniques of 2024: nominations open



James Kettle
Director of Research
[@albinowax](#)



Published: Wednesday, 8 January 2025 at 14:07 UTC

Updated: Wednesday, 22 January 2025 at 08:54 UTC



Nominations are now open for the top 10 new web hacking techniques of 2024!

Every year, security researchers from all over the world share their latest findings via blog posts, presentations, PoCs, and whitepapers. These contributions are all invaluable, but some stand out for their innovative approaches and the potential to be re-applied or adapted in new ways. Since 2006, the community has come together annually to sift through this wealth of research and identify the top ten techniques that truly push the boundaries of web security.

Now it's time to look back on 2024's breakthroughs and forward to recognizing the most influential, inventive, and reusable research. Whether you're an industry veteran or new to the project, you can explore our [dedicated top 10 page](#) to learn about the origins, history, and purpose of this initiative—plus an archive of past winners and highlights. Nominate your favorites, cast your votes, and help us crown the standout web hacking techniques of 2024!

This year, we'll target the following timeline:

Timeline

- Jan 8-14: Collect community nominations for the top research from 2024
- Jan 15-21: Community votes on nominations to build a shortlist of the top 15
- Jan 22: Launch panel vote on shortlist to select and order the 10 finalists
- Feb 04: Publish top 10 of 2024!

What should I nominate?

The aim is to highlight research containing novel, practical techniques that can be re-applied to different systems. Individual vulnerabilities like log4shell are valuable at the time but typically age poorly, whereas underlying techniques such as JNDI Injection can be reapplied to great effect. Nominations can also be refinements to already-known attack classes, such as Exploiting XXE with Local DTD Files. For further examples, you might find it useful to check out previous year's top 10s.

Making a nomination

To submit, simply provide a URL to the research, and an optional brief comment explaining what's novel about the work. Feel free to make as many nominations as you like, and nominate your own work if you think it's worthy!

[Click here to submit a nomination](#)

Please note that I'll filter out nominations that are non-web focused, just tools, or not clearly innovative to keep the number of options in the community vote manageable. We don't collect email addresses - to get notified when the voting stage starts, follow [@PortSwiggerRes](#) on [X](#), [LinkedIn](#), or [BlueSky](#).

Nominations

I've made a few nominations myself to get things started, and I'll update this list with fresh community nominations every few days. In the spirit of excessive automation, I've included AI-assisted summaries of each entry.

[Gotta cache 'em all: bending the rules of web cache exploitation](#)

Novel techniques exploiting URL parsing discrepancies to achieve arbitrary web cache poisoning and deception.

[Listen to the whispers: web timing attacks that actually work](#)

Making HTTP/2 timing attacks feasible and effective across diverse web environments by addressing network and server noise through novel techniques like single-packet sync and exploiting scoped SSRF opportunities.

[Splitting the email atom: exploiting parsers to bypass access controls](#)

Exploiting email parsing discrepancies using encoded words and unicode overflows for access control bypass and potential RCE in web applications.

[Confusion Attacks: Exploiting Hidden Semantic Ambiguity in Apache HTTP Server!](#)

Exploiting architectural flaws in Apache HTTP Server's module interactions to achieve insecure path access, predictable handler manipulation, and authentication bypass.

[Insecurity through Censorship: Vulnerabilities Caused by The Great Firewall](#)

Exploiting China's DNS poisoning for subdomain takeover via Fastly or XSS via vulnerable cPanel installations.

Bypassing WAFs with the phantom \$Version cookie

Bypassing WAFs using legacy support in cookie parsers through the \$Version attribute and quoted-string encoding.

ChatGPT Account Takeover - Wildcard Web Cache Deception

Exploiting path traversal confusion in CDN and web server URL parsing to cache sensitive API endpoints for auth token theft.

Why Code Security Matters - Even in Hardened Environments

Exploiting an arbitrary file write vulnerability in a Node.js application to achieve remote code execution by writing to pipe file descriptors exposed via procsfs.

Remote Code Execution with Spring Properties

Leveraging Spring Boot's logging configuration properties to achieve remote code execution through Logback's JoranConfigurator.

Exploring the DOMPurify library: Bypasses and Fixes

Mutation XSS by leveraging node flattening, stack of open elements, and namespace confusion to bypass DOMPurify

Bench Press: Leaking Text Nodes with CSS

Leaking text node content by using CSS animations to measure character heights and exfiltrating data via image requests.

Source Code Disclosure in ASP.NET apps

Using .NET cookieless sessions to obtain source code.

http-garden: Differential fuzzing REPL for HTTP implementations.

Platform for finding novel HTTP request smuggling vectors.

plORMbing your Prisma ORM with Time-based Attacks

Using time-based attacks on Prisma ORM to leak sensitive data by crafting queries that exploit relational filtering to cause significant execution delays.

Introducing lightyear: a new way to dump PHP files

Automated high-speed exploitation with PHP filter chains

The Ruby on Rails _json Juggling Attack

The _json juggling attack manipulates JSON parameters to bypass authorization in Ruby on Rails by exploiting the handling of _json keys.

Encoding Differentials: Why Charset Matters

Exploiting ISO-2022-JP encoding to bypass sanitization and inject JavaScript when charset information is missing.

A Race to the Bottom - Database Transactions Undermining Your AppSec

Detailed analysis of patterns that enable race condition attacks on database transactions

[Response Filter Denial of Service \(RFDoS\): shut down a website by triggering WAF rule DoS technique exploiting overly inclusive WAF rules to block legitimate content delivery.](#)

[Unveiling TE.0 HTTP Request Smuggling: Discovering a Critical Vulnerability in Thousands of Google Cloud Websites](#)

A novel HTTP Request Smuggling vector affecting Google Cloud-hosted websites.

[DoubleClickjacking: A New Era of UI Redressing](#)

DoubleClickjacking exploits the timing gap between mousedown and onclick events to bypass clickjacking protections and hijack user actions.

[Devfile file write vulnerability in GitLab](#)

Exploiting YAML parser differentials and path traversal in tar file extraction to achieve arbitrary file write in GitLab.

[Breaking Down Multipart Parsers: File upload validation bypass](#)

Techniques to bypass multipart/form-data parsers by exploiting discrepancies in parameter handling, boundary recognition, and content validation, including duplicated parameters, omission of necessary delimiters, and alternate encoding sequences.

[Supply Chain Attacks: A New Era](#)

Bypassing Lavamoat's policy file sandboxing through crafted multiline source map comments and evading SnowJS realm isolation via the deprecated document.execCommand function.

[Abusing Intended Feature And Bypassing Facial Recognition.pptx](#)

Bypassing facial recognition by exploiting AI's inability to distinguish between live human faces and deepfake images.

[Arc Browser UXSS, Local File Read, Arbitrary File Creation and Path Traversal to RCE](#)

Techniques to exploit Arc Browser include installing malicious boosts via UI spoofing, achieving Local File Read and Path Traversal for Remote Code Execution by manipulating boost configuration paths.

[Beyond the Limit: Expanding single-packet race condition with a first sequence sync for breaking the 65,535 byte limit](#)

Expanding single-packet attack's capabilities by utilizing IP fragmentation and TCP sequence number reordering to exploit limit-overflow vulnerabilities.

[HTTP/2 CONTINUATION Flood: Technical Details](#)

HTTP/2 CONTINUATION Flood attack enables denial of service by exhausting server resources with an unending stream of headers lacking an END_HEADERS flag.

[Exploring Javascript events & Bypassing WAFs via character normalization](#)

AI fail

[From Arbitrary File Write to RCE in Restricted Rails apps](#)

Abusing Bootsnap's cache manipulation to execute arbitrary code in restricted Rails environments.

[Go Go XSS Gadgets: Chaining a DOM Clobbering Exploit in the Wild](#)

Chaining DOM Clobbering with postMessage and CSP bypasses to escalate XSS.

Statamic CMS

Path traversal through filename manipulation in file uploads.

Exploiting Number Parsers in JavaScript

Exploiting discrepancies in JavaScript number parsers for DoS via parameter pollution.

[EN] Unsecure time-based secret and Sandwich Attack

AI fail

DoubleClickjacking: A New Era of UI Redressing

DoubleClickjacking is a novel UI redressing technique exploiting timing and event-order quirks in double-click sequences to bypass clickjacking protections.

Cross Window Forgery: A New Class of Web Attack

The paper introduces "Cross Window Forgery," a new web attack technique using browser navigation and keystrokes to execute actions on different websites via URL fragments.

Exploiting Client-Side Path Traversal to Perform Cross-Site Request Forgery - Introducing CSPT2CSRF

Exploiting Client-Side Path Traversal for CSRF by chaining GET and POST actions (CSPT2CSRF).

Class Pollution in Ruby: A Deep Dive into Exploiting Recursive Merges

Recursive merge technique in Ruby to achieve class pollution for privilege escalation and RCE.

Unveiling the Prototype Pollution Gadgets Finder

Automated exploitation of server-side prototype pollution using gadget identification.

Hijacking OAUTH flows via Cookie Tossing

Hijacking OAUTH flows via Cookie Tossing for Account Takeovers

Break the Wall from Bottom: Automated Discovery of Protocol-Level Evasion Vulnerabilities in Web Application Firewalls

Automated discovery of protocol-level evasion vulnerabilities in WAFs using a novel testing methodology that exploits parsing discrepancies between WAF and web applications.

Old new email attacks

Exploiting inconsistent parsing of email headers across services for email spoofing and SMTP injection.

CVE-2023-5480: Chrome new XSS Vector

Exploiting Service Worker registration in JIT-installed workers for XSS via manipulated payment manifests in Chrome.

Wormable XSS www.bing.com. XSS on www.bing.com context via Maps...

Wormable XSS on Bing using KML file and mixed-case JavaScript to bypass blacklist.

Another vision for SSRF

Using SSRF to capture session cookies by directing requests to a controlled server.

WorstFit: Unveiling Hidden Transformers in Windows ANSI!

Exploiting Windows Best-Fit character conversion for attacks like Path Traversal, Argument Injection, and RCE across various applications.

Lost in Translation - WAF Bypasses By Abusing Data Manipulation Processes

Abusing edge-side includes and Unicode manipulation to bypass WAF.

Piloting Edge Copilot

Sending javascript: URL via postMessage to exploit an XSS vulnerability on Bing.

POST to XSS: Leveraging Pseudo Protocols to Gain JavaScript Evaluation in SSO Flows

Exploiting the javascript: pseudo-protocol with auto-submitting forms in OAuth 2.0 Form Post Response Mode and SAML POST-Binding to achieve XSS.

Bypassing CSP via URL Parser Confusions: XSS on Netlify's Image CDN

Bypassing strict CSP using URL parser confusions to achieve XSS on Netlify's Image CDN.

Iconv, set the charset to RCE: Exploiting the glibc to hack the PHP engine

Exploiting a buffer overflow in glibc's iconv function to achieve remote code execution in PHP applications, such as Roundcube, by manipulating session variables or leveraging deserialization vulnerabilities.

Zoom Session Takeover - Cookie Tossing Payloads, OAuth Dirty Dancing, Browser Permissions Hijacking, and WAF abuse

Cookie tossing to escalate XSS vulnerabilities, OAuth Dirty Dancing for session takeover, and leveraging XSS for browser permission hijacking and DoS through WAF Frame-up techniques.

Unveiling Rhino's Blind Spot: Exploiting Custom Code Execution in Apigee

Exploiting the interplay between JavaCallout and JavaScript policies in Apigee to bypass security controls and achieve Remote Code Execution.

NetModule Router Software Race Condition Leads to Remote Code Execution

A race condition in NetModule Router Software enables remote code execution by exploiting process state files.

SQL Injection Isn't Dead Smuggling Queries at the Protocol Level

Protocol-level SQL injection attacks via database wire protocol smuggling.

Excessive Expansion: Uncovering Critical Security Vulnerabilities in Jenkins

The text describes leveraging the "expandAtFiles" functionality in Jenkins to read arbitrary files and potentially execute arbitrary code on the server.

Joomla: PHP Bug Introduces Multiple XSS Vulnerabilities

Exploiting inconsistencies in PHP mbstring functions to bypass Joomla's input sanitization leading to XSS vulnerabilities.

Gudifu: Guided Differential Fuzzing for HTTP Request Parsing Discrepancies

Gudifu uses guided differential fuzzing to discover HTTP request parsing discrepancies that can lead to new attack vectors such as HTTP request smuggling and cache poisoning.

MSSQL Identified as Vulnerable to Emoji String Exploitation

Exploiting Unicode collation logic discrepancies in MSSQL to treat a goblin emoji as an empty string, enabling brute-force attacks.

Ruby 3.4 Universal RCE Deserialization Gadget Chain

Developing a universal RCE deserialization gadget chain for Ruby 3.4 that leverages RubyGems autoloading, uses 'rake' and 'make' commands for execution, and suppresses exceptions using an UncaughtThrowError object.

CVE-2024-50603: Aviatrix Network Controller Command Injection Vulnerability

Injecting malicious payloads via unsanitized cloud_type parameter to execute arbitrary commands on Aviatrix Network Controller.

CORS vulnerabilities: Weaponizing permissive CORS configurations

Reflected arbitrary origins and alternate domain/subdomain trust in CORS configurations can permit unauthorized data exfiltration.

Attacking PowerShell CLIXML Deserialization

Exploiting PowerShell's CLIXML deserialization can lead to Remote Code Execution by leveraging user-defined types, CimInstance rehydration, and vulnerabilities in widely deployed modules, allowing VM escape and attacks on PowerShell Remoting.

Ruby-SAML / GitLab Authentication Bypass (CVE-2024-45409)

Exploiting XPath vulnerabilities to bypass SAML signature validation in Ruby-SAML.

World of SELECT-only PostgreSQL Injections

Offline manipulation of PostgreSQL filenodes for privilege escalation and RCE.

Hacking Giants Through a Race Condition in GitHub Actions Artifacts

The text does not contain a novel or innovative web hacking technique.

Hacking Millions of Modems (and Investigating Who Hacked My Modem)

Unauthorized access to ISP-managed TR-069 APIs via authorization bypass, leading to full device takeover.

Exploiting the Unexploitable Insights from the Kibana Bug Bounty

AI fail.

DEF CON 32 - SQL Injection Isn't Dead: Smuggling Queries at the Protocol Level

AI fail.

Teaching the Old .NET Remoting New Exploitation Tricks

Bypassing .NET Remoting security by leveraging XAML parsing to perform deserialization attacks that create privileged objects like WebClient for remote code execution despite TypeFilterLevel.Low and CAS restrictions.

Efficient Detection of Java Deserialization Gadget Chains via Bottom-up Gadget Search and Dataflow-aided Payload Construction

Using a bottom-up approach to more efficiently detect Java deserialization gadget chains and leveraging

data flow dependencies for payload generation.

Undefined-oriented Programming: Detecting and Chaining Prototype Pollution Gadgets in Node.js Template Engines for Malicious Consequences

Detecting and chaining indirect JavaScript prototype pollution gadgets using undefined properties for complex attack vectors like ACE and RCE..

JNDI Injection Remote Code Execution via Path Manipulation in MemoryUserDatabaseFactory

JNDI injection to manipulate the pathname in MemoryUserDatabaseFactory for remote code execution via crafted XML and directory creation using BeanFactory method invocation.

GitHub Actions exploitation: untrusted input

GitHub Actions can be exploited through misconfigurations such as untrusted input in triggers (e.g., pull_request_target), potentially allowing arbitrary code execution and unauthorized repository modifications.

a-deep-dive-into-openapi-security.pdf

AI fail.

[EN] Multi-sandwich attack with MongoDB Object ID or the scenario for real-time monitoring of web application invitations: a new use case for the sandwich attack

Multi-sandwich attack exploiting MongoDB Object ID's predictable counter to monitor and intercept tokens in real-time.

Secret Web Hacking Knowledge: CTF Authors Hate These Simple Tricks

The text does not contain a novel or innovative web hacking technique.

Facebook Messenger Bug Hunting - A Bug's E2E Lifecycle

The text does not contain a novel or innovative web hacking technique.

Android Exploit to RCE: \$5000 Bounty

Tricking a headless browser into executing arbitrary JavaScript for server-side RCE with DNS tunneling for data exfiltration.

XSS Vulnerabilities in Excalidraw Affecting Meta (CVE-2024-32472)

Sandbox escape via gist.github iframe in Excalidraw allows arbitrary JavaScript execution.

1 bug, \$50,000+ in bounties, how Zendesk intentionally left a backdoor in hundreds of Fortune 500 companies

Exploiting Zendesk's lack of email spoofing safeguards to hijack ticket threads and gain unauthorized access to Slack accounts using OAuth.

Hacking Kia: Remotely Controlling Cars With Just a License Plate

Exploiting Kia's dealer token generation to remotely control vehicles using only a license plate and a sequence of backend API requests.

Using YouTube to steal your files Ǿ

Chaining multiple open redirect vulnerabilities in YouTube and Google Docs to perform a clickjacking

attack granting editor access to Google Drive files.

Bidding Like a Billionaire - Stealing NFTs With 4-Char CSTIs

Exploiting Vue.js CSTI through ENS name truncation to achieve XSS and manipulate NFT bids.

Chaining Three Bugs to Access All Your ServiceNow Data

Bypassing ServiceNow's template injection mitigations via sanitized style tag content for code execution.

Universal Code Execution by Chaining Messages in Browser Extensions

Chaining messaging APIs in browser extensions to bypass Same Origin Policy and trigger native application vulnerabilities for universal code execution.

Leaking Jupyter instance auth token chaining CVE-2023-39968, CVE-2024-22421 and a chromium bug

Client-side path traversal chained with an open redirect and a Chromium bug to leak authentication and CSRF tokens.

Next.js and cache poisoning: a quest for the black hole

Exploiting internal headers in Next.js to control HTTP status codes and cache error pages.

CVE-2024-4367 - Arbitrary JavaScript execution in PDF.js

Arbitrary JavaScript execution through manipulated FontMatrix in PDF.js font rendering.

Bypassing WAFs to Exploit CSPT Using Encoding Levels

Bypassing WAFs by exploiting discrepancies between URL encoding levels and application decoding levels.

You can't securely execute commands on Windows

Command injection through improper escaping of command arguments when executing batch files via CreateProcess on Windows.

XSS using dirty Content Type in cloud era

XSS through manipulation of Content-Type headers.

Hello Lucee! Let us hack Apple again?

Exploiting deserialization in Lucee CFML servers with REST endpoints for RCE and leveraging vulnerable CFML expression parsing for RCE in Mura CMS.

Rook to XSS: How I hacked chess.com with a rookie exploit

Using a TinyMCE misconfiguration to achieve XSS by manipulating background-image URL attributes.

Back to the (Clip)board with Microsoft Whiteboard and Excalidraw in Meta (CVE-2023-26140)

Exploiting the Clipboard API to inject XSS payloads through poisoned clipboard data in collaborative whiteboard applications.

SMTP Smuggling - Spoofing E-Mails Worldwide

Using different interpretations of SMTP end-of-data sequences to send spoofed emails across domains, bypassing SPF alignment checks (SMTP smuggling).

Cloudflare Pagesにおける権限昇格と任意ページの改竄

File read using symbolic links with misconfigured processing, npm package manipulation for privilege escalation using URL versions, and path traversal exploiting lax path validation on Cloudflare Pages.

Half Measures and Full Compromise: Exploiting Microsoft Exchange PowerShell Remoting

Chain of Arbitrary File Write, Arbitrary File Read, and Local DLL Loading for RCE on Exchange.

SOQL injection

Exploiting unrestricted SOQL query endpoints to exfiltrate sensitive Salesforce data.

Few steps on how to take over a whole application

Exploiting predictable reset token patterns within audit logs for arbitrary account takeover.

Crashing servers with digits

Exploiting floating-point numbers with excessive digits to cause server DoS.

User info extraction abusing placeholder injection in Zendesk

User info extraction using placeholder injection via subject-to-description sanitization bypass in Zendesk.

Authorization bypass due to cache misconfiguration

Authorization bypass due to short-term caching vulnerability.

Dancer in the Dark: Synthesizing and Evaluating Polyglots for Blind Cross-Site Scripting

Synthesizing polyglot payloads for detecting blind XSS across multiple injection contexts without feedback channels.

Parse Me, Baby, One More Time: Bypassing HTML Sanitizer via Parsing Differentials

Bypassing HTML sanitizers using parsing differentials to exploit mutation-based XSS vulnerabilities.

MongoDB NoSQL Injection with Aggregation Pipelines

Accessing other collections via NoSQL injection in MongoDB aggregation pipelines using \$lookup or \$unionWith operators.

Delinea Protocol Handler - Remote Code Execution via Update Process (CVE-2024-12908)

Exploiting sslauncher URL handler to achieve Remote Code Execution via MSI transform abuse.

Anyone can Access Deleted and Private Repository Data on GitHub

Cross Fork Object Reference (CFOR) vulnerability enables unauthorized access to sensitive data in deleted and private GitHub repositories using commit hashes.

plORMbing your Django ORM

Exploiting relational filtering in Django ORM to leak sensitive data through many-to-many relationship and permission models.

[Quick note] How to build CodeQL DB with closed-source project(.NET Assembly) | by Jang

The text does not contain a novel or innovative web hacking technique.

Abusing Arbitrary File Deletes to Escalate Privilege and Other Great Tricks

Abusing the Windows Installer service by exploiting an arbitrary folder delete vulnerability to gain

SYSTEM-level privilege escalation.

[GHSL-2024-312: Arbitrary code execution and secret exfiltration in Azure API Management Developer Portal](#)

Exploiting untrusted data interpolation in CI workflows for code execution.

[How an obscure PHP footgun led to RCE in Craft CMS](#)

Abusing the register_argc_argv PHP configuration to manipulate Craft CMS path handling and achieve Remote Code Execution via the FTP wrapper in Twig templates.

[Zero Day Initiative — SolarWinds Access Rights Manager: One Vulnerability to LPE Them All](#)

Exploiting pre-auth arbitrary file deletion via gRPC to perform LPE on domain-joined Windows machines.

[Databricks JDBC Attack via JAAS](#)

Exploiting krbJAASFile in Databricks JDBC for remote code execution via JNDI injection.

[Gem::SafeMarshal escape](#)

Exploiting a deserialization primitive in Gem::SafeMarshal via Ruby's Date class to achieve arbitrary command execution.

[OAuth Non-Happy Path to ATO](#)

Using multiple response_type values in Google OAuth to capture both id_token and authorization code in the URL fragment for account takeover.

[Tyrannid's Lair: Working your way Around an ACL](#)

No novel or innovative web hacking technique.

[CVE-2023-50220 — Inductive Automation Ignition XML Deserialization to RCE](#)

Exploiting XML Deserialization vulnerability to achieve RCE using a modified Jython gadget chain.

[Exploiting Exchange PowerShell After ProxyNotShell: Part 1 - MultiValuedProperty](#)

Exploiting deserialization in Exchange PowerShell by abusing allowed generic types like MultiValuedProperty to achieve RCE.

[A New Attack Interface In Java Application](#)

Exploiting Java applications through JDBC drivers

Top 10 Hacking Techniques

top-10-techniques

[← Back to all articles](#)

Related Research





Burp Suite

Web vulnerability scanner
Burp Suite Editions
Release Notes

Vulnerabilities

Cross-site scripting (XSS)
SQL injection
Cross-site request forgery
XML external entity injection
Directory traversal
Server-side request forgery

Customers

Organizations
Testers
Developers

Company

About
Careers
Contact
Legal
Privacy Notice
Modern Slavery Statement

Insights

Web Security Academy
Blog
Research
Engineering



© 2026 PortSwigger Ltd.

